



بنك الآفاق الرقمية | DIGITAL HORIZONS BANK

نظام إدارة أمن المعلومات (ISMS) وإدارة استمرارية الأعمال (BCM)

خطة استمرارية الأعمال والتعافي من الكوارث

Disaster Recovery and Business Continuity Plan

تصنيف الوثيقة (CLASSIFICATION)	داخلي (Internal) — لا يجوز مشاركتها خارجياً دون موافقة خطية مسبقة من مالك الوثيقة.
مرجع الوثيقة (DOCUMENT REF)	ISMS-BCP-DR-G12
الإصدار (VERSION)	1.0 (مُعتمد)
معتمد من (APPROVED BY)	د. نورة القحطاني (الرئيس التنفيذي) ولجنة المخاطر بمجلس الإدارة
مالك الوثيقة (OWNER)	أ. ريان السبيعي (مدير استمرارية الأعمال والتعافي) بإشراف CISO أ. سارة الحربي
تاريخ آخر تحديث (DATE LAST UPDATED)	12 سبتمبر 2026 (دورية المراجعة: سنوي / المراجعة القادمة: سبتمبر 2027)
الملاحظات (COMMENTS)	الخطة التشغيلية والتقنية الشاملة لإدارة استمرارية الأعمال المصرفية والتعافي من الكوارث لبنك الآفاق الرقمية.

المقدمة والنطاق (Introduction & Scope)	3
الغرض والمواءمة المعيارية (Purpose & Standards alignment)	3
النطاق التشغيلي والتقني (Scope)	3
ضمان استمرارية الموردين وسجل الموردين (Supplier continuity register)	4
معايير التفعيل وإنهاء حالة الطوارئ (Activation criteria & stand-down)	4
تحليل الأثر على الأعمال (Business Impact Analysis - BIA)	5
جدول تحليل الأثر على الأعمال (BIA Table)	5
تقييم المخاطر وتصنيف الأثر (Risk Assessment & Impact Ratings)	6
أصحاب المصلحة الرئيسيون والمسؤوليات ومصفوفة الأدوار (Key Stakeholders)	7
استراتيجية النسخ الاحتياطي والاستعادة (Backup & restore strategy)	8
إجراءات العمل البديلة واليدوية (Manual workarounds summary table)	9
سجل الاعتماديات الحرجة ونقاط الفشل الفردية (Critical dependency register - SPOF)	9
سيناريوهات الكوارث وخطة التعافي التقني (Disaster Scenarios & Recovery Plan)	10
خطط الاستجابة والتواصل أثناء الكوارث (Incident Response & Communication Plans)	12
مراحل الاستجابة السبع للحادث الجسيم (7 Phases of Major Incident)	12
خطة التواصل والرسائل المعتمدة (Communication Plan)	13
المراجعة والصيانة والاختبار المستمر (Review, Maintenance & Testing)	15
جدول الاختبارات المستقبلية (Forward test schedule)	15
الملاحق (Appendices)	16
الملحق أ: استمارة بيانات الاتصال في الطوارئ (Appendix A - Contact Info)	16
الملحق ب: الأدوار والنواب المعينون (Appendix B - Roles with named alternates)	17
الملحق ج: قائمة التحقق الميدانية للتفعيل (Appendix C - DR/BCP Activation Checklist)	17

المقدمة والنطاق (Introduction & Scope)**الغرض (Purpose)**

تحدد هذه الخطة المتكاملة لاستمرارية الأعمال والتعافي من الكوارث (DR/BCP) كيفية استعداد واستجابة وتعافي بنك الآفاق الرقمية (Digital Horizons Bank) من الأحداث الكارثية والاضطرابات الجسيمة التي قد تهدد استمرارية العمليات المصرفية. وتدمج هذه الخطة بين استمرارية الأعمال المؤسسية (الأفراد، العمليات، سلاسل الإمداد، والتواصل) والتعافي التقني من الكوارث (البنية التحتية، مراكز البيانات، السحابة، والأنظمة) في إطار موحد ومتناسب مع متطلبات القطاع المالي.

المواءمة المعيارية والرقابية (Standards Alignment)

صُممت هذه الخطة لتلبي بشكل كامل متطلبات الضابط A.5.30 من مواصفة ISO/IEC 27001:2022 (جاهزية تكنولوجيا المعلومات والاتصالات لاستمرارية الأعمال - ICT readiness for business continuity)، ومعيار ISO 22301 لإدارة استمرارية الأعمال، بالإضافة إلى الامتثال الصارم لتعليمات البنك المركزي السعودي (SAMA) لإدارة استمرارية الأعمال وإطار الأمن السيبراني (SAMA CSF). تضمن الخطة قدرة تكنولوجيا المعلومات على دعم أهداف الاستمرارية عبر تحديد أوقات التعافي المستهدفة (RTO)، ونقاط التعافي المستهدفة (RPO)، والحد الأقصى المسموح به للتوقف (MAD).

النطاق التشغيلي والتقني (Scope)

يغطي نطاق هذه الخطة كافة خدمات تكنولوجيا المعلومات والاتصالات الحيوية التي تدعم منتجات العملاء والعمليات المصرفية الأساسية، وتشمل:

- الأنظمة المصرفية الأساسية (Core Banking System) وقواعد بيانات الحسابات والودائع في مركز بيانات الرياض الرئيسي ومركز التعافي بجدة.
- قنوات الصيرفة الرقمية: البوابة المصرفية عبر الإنترنت وتطبيقات الهواتف الذكية (iOS & Android).
- بوابات الدفع والتحويلات المالية الوطنية والدولية (سريع SARIE، مدى Mada، وشبكة سويفت SWIFT).
- أحمال العمل والبيانات السحابية (AWS S3, EC2)، ومستودعات الأكود ومسارات النشر الآلي (CI/CD).
- خدمات الهوية المركزية والدخول الموحد (SSO/Active Directory)، وإدارة التسمية (DNS)، والبريد الإلكتروني للعملاء.
- أجهزة المستخدمين ومحطات العمل البنكية البالغ عددها 2,000 جهاز محمول ومكتبي.
- استثناءات النطاق: ما يقع خارج النطاق الداخلي ويتم ضمان استمراريته عبر الموردين والخدمات السحابية الموثوقة: أنظمة إدارة الموارد البشرية السحابية المساعدة، وبوابات الدعم المستقلة؛ حيث تخضع لبروتوكول ضمان استمرارية الموردين وسجل الضمانات أدناه.

ضمان استمرارية الموردين والخدمات السحابية (Supplier & SaaS Continuity Assurance)

عندما تعتمد الخدمات المصرفية على أطراف خارجية أو خدمات سحابية، فإننا نطبق آلية ضمان الاستمرارية والتحقق المباشر من خطط التعافي الخاصة بهم، وتشمل المعايير الإلزامية:

- اتفاقيات مستوى الخدمة (SLA): تحديد أهداف RTO و RPO وتوافر الخدمة بنسبة لا تقل عن 99.9%.
- الشهادات والتقارير المستقلة: الحصول على تقارير SOC 2 Type II وشهادات ISO 27001 سارية سنوياً.
- مراقبة الحالة: الاشتراك في بوابات الرصد المباشر لحالة الخدمات السحابية وقنوات التصعيد الطارئة.
- حماية البيانات والتكرار الجغرافي: تفعيل التوزيع عبر مناطق متعددة (Multi-AZ / Cross-Region).

المالك الداخلي (Internal Owner)	وثائق الضمان (Assurance)	المستهدف (Expected) (RTO/RPO)	حرجية؟ (?Critical)	نوع الاعتمادية (Dependency Type)	المورد / الخدمة (Supplier / Service)
مدير الأنظمة والشبكات	SOC 2 Type II, SLA 99.99% حسابات Break-Glass	RTO: 1 ساعة / RPO: 15 دقيقة	نعم (Yes)	إدارة الهويات والمصادقة SSO	مزود الهوية (Microsoft Entra ID / AD)
رئيس أمن الشبكات	ISO 27001, تفعيل DNS احتياطي فوري	RTO: 30 دقيقة / RPO: 0	نعم (Yes)	توجيه أسماء النطاقات DNS	مزود خدمة التسمية (Cloudflare / stc DNS)
مدير السحابة والتحول الرقمي	ISO 27001, SOC Multi-3/2/1 Region replication	RTO: 4 ساعات / RPO: 1 ساعة	نعم (Yes)	الحوسبة والتخزين S3/EC2	المزود السحابي (AWS Middle East)
مشرف أنظمة التعاون المؤسسي	SOC 2, SLA 99.9%, تفعيل قنوات SMS وبوابات بديلة	RTO: 4 ساعات / RPO: 2 ساعة	نعم (Yes)	المراسلات والاتصالات الرسمية	مزود البريد الإلكتروني (M365 Exchange)
رئيس هندسة البرمجيات	نسخ احتياطي يومي مشفر خارج الموقع	RTO: 4 ساعات / RPO: 0	نعم (Yes)	مستودعات الأكواد ومسار CI/CD	منصة النشر والتطوير (GitLab Enterprise)

مرجع: الجدول 1: سجل ضمان استمرارية الموردين والخدمات السحابية (Supplier continuity register)

معايير التفعيل وإنهاء حالة الطوارئ (Activation Criteria & Stand-Down)

يتم تفعيل خطة استمرارية الأعمال والتعافي من الكوارث (DR/BCP) رسمياً بقرار من مدير الحادث (Incident Manager - CISO) أو نائبه عند تحقق أي من الحالات التالية:

- توقف أو تدهور حرج في خدمة مصرفية موجهة للعملاء (مثل القنوات الرقمية أو التحويلات) لأكثر من 30 دقيقة وتعذر حلها بالمعالجة الاعتيادية.
- حادث أمني جسيم (مثل هجوم فدية أو تلف قواعد البيانات) يهدد سلامة البيانات أو يتجاوز أهداف RTO و RPO المعتمدة.
- فشل غير قابل للاستعادة في أحد المكونات الحرجة (مركز البيانات الرئيسي، الدومين، السحابة).
- فقدان الموقع المادي وتعذر الوصول إلى المقر الرئيسي أو مركز بيانات الرياض لأكثر من يوم عمل واحد.
- صلاحية اتخاذ القرار: صلاحية التفعيل: تعود الصلاحية الحصرية لمدير الحادث (CISO) بالتشاور مع الرئيس التنفيذي ومدير استمرارية الأعمال.

شروط إنهاء الطوارئ: إنهاء الطوارئ (Stand-Down): تعلن العودة للتشغيل الطبيعي بموافقة مشتركة بين مدير الحادث ومالك العمليات بعد التحقق من استقرار الأنظمة وتطابق البيانات وعقد جلسة الدروس المستفادة خلال 10 أيام عمل.

تحليل الأثر على الأعمال (Business Impact Analysis - BIA)

يوثق هذا القسم مخرجات دراسة تحليل الأثر على الأعمال، محدداً أهداف الاستعادة المصرفية الحيوية:

- الحد الأقصى المسموح به للتوقف (MAD - Maximum Allowable Downtime): أطول فترة زمنية يمكن للبنك تحمل انقطاع الخدمة بعدها قبل حدوث أضرار لا يمكن تداركها.
- زمن التعافي المستهدف (RTO - Recovery Time Objective): الوقت المستهدف لاستعادة الخدمة وتشغيلها مجدداً.
- نقطة التعافي المستهدفة (RPO - Recovery Point Objective): أقصى حد زمني مسموح به لفقدان البيانات (عمر البيانات المستعادة).

الوظيفة المصرفية (Function)	النظام / العملية (System)	أثر التوقف (Impact)	MAD	RTO	RPO	استراتيجية التخفيف (Mitigation)
قواعد البيانات المصرفية	Core Banking Database (الودائع والأرصدة)	كارثي: خسائر مالية فادحة ووقف العمليات وعقوبات SAMA	4 ساعات	2 ساعة	5 دقائق	مزامنة لحظية متزامنة مع مركز بيانات جدة، ونسخ WORM يومية معزولة
قنوات الصيرفة الرقمية	تطبيقات الجوال والإنترنت البنكي	حرج: شلل الخدمات لآلاف العملاء وضرر بليغ بالسمعة	4 ساعات	2 ساعة	15 دقيقة	بنية سحابية هجينة متعددة المناطق وخدمة حماية DDOS من Cloudflare
بوابات الدفع الوطنية	شبكات مدى Mada SARIE ونظام سريع	حرج: تعطل نقاط البيع والتحويلات بين البنوك والمساءلة	2 ساعة	1 ساعة	صفر	خطوط اتصال مزدوجة مع البنك المركزي وتوزيع حركة المرور
منصة سويفت الدولية	SWIFT Alliance Gateway	كبير: تعطل التحويلات المالية الدولية والاعتمادات	6 ساعات	4 ساعات	صفر	خادم سويفت احتياطي ساخن في مركز بيانات جدة وفق معايير CSP
التخزين السحابي للبيانات	مستودعات AWS S3 (بيانات العملاء)	حرج: فقدان وثائق ومعاملات العملاء ومخالفة PDPL	6 ساعات	4 ساعات	1 ساعة	تفعيل خاصية Versioning، وتكرار عبر مناطق جغرافية Cross-Region
إدارة الشيفرة البرمجية	مستودعات Git ومسار CI/CD	متوسط: تأخر التطوير دون مساس بالخدمات الحية	8 ساعات	4 ساعات	12 ساعة	نسخ متماثلة موزعة للمطورين ونسخ احتياطي يومي مشفر

مراجع: الجدول 2: مصفوفة تحليل الأثر على الأعمال وأهداف التعافي (BIA Table)

مركز اعتماد الإدارة لحدود الأثر والتحمل (Management Acceptance): تمت مراجعة واعتماد حدود التوقف وأهداف RTO و RPO الموضحة أعلاه من قبل الإدارة التنفيذية ومجلس الإدارة، مع قبول المخاطر المتبقية في ظل الجدوى الاقتصادية للحلول التقنية المتاحة.

الاعتماد: د. نورة القحطاني (الرئيس التنفيذي) | التاريخ: 12 سبتمبر 2026.

تقييم المخاطر وتصنيف الأثر (Risk Assessment & Impact Ratings)

يوضح الجدول 3 أدناه تصنيف شدة الأثر المتوقع في حال تعطل كل وظيفة مصرفية عبر المجالات الأربعة الرئيسية:

الأثر التشغيلي (Operational)	الأثر التنظيمي (Regulatory)	أثر السمعة (Reputation)	الأثر المالي (Financial)	مجال الخطر (Risk Area)
عالي (High)	عالي (High)	عالي (High)	عالي (High)	الأنظمة المصرفية وقواعد البيانات الأساسية
عالي (High)	متوسط (Medium)	عالي (High)	عالي (High)	قنوات الصيرفة الرقمية (الويب والجوال)
عالي (High)	عالي (High)	عالي (High)	عالي (High)	بوابات الدفع الوطنية (مدى وسريع وسويقت)
متوسط (Medium)	منخفض (Low)	منخفض (Low)	منخفض (Low)	مستودعات الأكواد وبيانات النشر CI/CD

مرجع: الجدول 3: تصنيف شدة الأثر عبر المجالات الرئيسية (Risk Assessment & Impact Ratings)

أصحاب المصلحة الرئيسيون والمسؤوليات (Key Stakeholders & Responsibilities)

يوضح الجدول 4 مصفوفة توزيع المسؤوليات والصلاحيات أثناء إدارة الكوارث بين: الإدارة العليا التنفيذية (Senior Exec Team)، لجنة ومسؤولي أمن المعلومات (ISG)، إدارة تقنية المعلومات (IT)، وشركة التأمين السيبراني.

النشاط / الوظيفة التشغيلية (Activity / Function)	الإدارة العليا (Exec)	أمن المعلومات (ISG)	تقنية المعلومات (IT)	شركة التأمين (Insurance)
قرار تفعيل خطة الكوارث والاستمرارية (DR/BCP) (Activation)	A	R	C	I
إدارة الاتصالات الداخلية لفرق وموظفي البنك	A	R	C	—
إدارة الاتصالات الخارجية (العملاء، SAMA، الإعلام)	A / R	C	C	—
التعافي التقني لمستودعات البيانات السحابية AWS S3	I	R	C	—
التعافي من فقدان المقر أو مركز بيانات الرياض والتحول لخدمة	A	R	C	—
استعادة قواعد بيانات الصيرفة والأنظمة الأساسية	I	C	R	—
استعادة بيئة النشر ومستودعات الأكواد البرمجية	I	R	C	—
معالجة هجمات الفدية على أجهزة المستخدمين الـ 2000	I	C	R	I
الاستجابة للحوادث السيبرانية واختراقات البيانات	A	R	C	I
تقييم الأثر والمخاطر التشغيلية والمالية أثناء الكارثة	A	R	C	—
التنسيق مع شركة التأمين لتقديم المطالبات وتغطية الخسائر	A	C	I	R
مراجعة ما بعد الحادث واستخلاص الدروس المستفادة (PIR)	A	R	C	—
إجراء الاختبارات والتمارين السنوية لخطة التعافي	A	R	C	—

مرجع: الجدول 4: مصفوفة المسؤوليات أثناء تفعيل خطة الطوارئ (Key Stakeholders RACI)

مفتاح الرموز: (R) مسؤول التنفيذ المباشر | (A) المساعِل وصاحب القرار النهائي | (C) مستشار يقدم الدعم والخبرة | (I) يُخطر ويُبلغ بالنتائج.

استراتيجية النسخ الاحتياطي والاستعادة (Backup & Restore Strategy)

تهدف استراتيجية النسخ الاحتياطي إلى ضمان حماية كافة البيانات المصرفية والتهينات التقنية لتحقيق أهداف RPO والتعافي ضمن أهداف RTO:

- دورية النسخ لقواعد البيانات: قواعد البيانات المصرفية: نسخ تزايد كل ساعة، نسخ كامل يومي، مع الاحتفاظ بالنسخ لمدة لا تقل عن 30 يوماً وتكرارها فوراً لمركز بيانات جدة.
- التخزين السحابي: مستودعات التخزين السحابية (S3): تفعيل خاصية الإصدارات (Versioning) وحفظ التعديلات لمدة 90 يوماً مع تكرارها جغرافياً.
- ملفات التكوين: تهيئة البنية التحتية والشفيرات (IaC): حفظ يومي لكافة تكوينات البنية البرمجية وسيرفرات الدومين.
- أمن النسخ الاحتياطي: الحماية والأمان: تشفير كافة النسخ أثناء النقل والتخزين بتقنية AES-256، وحفظ نسخة معزولة غير قابلة للتعديل (WORM / Air-gapped) لمنع وصول برمجيات الفدية إليها.
- معايير نجاح الاستعادة: اختبارات الاستعادة الدورية: اختبار استعادة نقطة زمنية شهرياً، اختبار استعادة قاعدة بيانات كاملة في بيئة معزولة فصلياً، ومحاكاة سنوية كاملة للتحويل لمركز بيانات جدة.

إجراءات العمل البديلة واليدوية (Manual Workarounds Summary Table)

يوضح الجدول 5 خطط وإجراءات العمل المؤقتة البديلة المعتمدة لاستمرار الأعمال عند توقف الأنظمة التقنية الرئيسية:

العملية الحرجة (Critical Process)	إجراء العمل البديل المؤقت (Temporary Workaround)	المتطلبات المسبقة (Prerequisites)	أقصى مدة للبديل (Max Duration)	المالك (Owner)
تواصل العملاء عند تعطل البريد	استخدام صفحة حالة البنك الخارجية + الرسائل النصية القصيرة SMS وإشعارات التطبيق المباشرة	قائمة أرقام هواتف العملاء وقوائم الرسائل الجاهزة	48 ساعة	مدير رعاية العملاء
وصول الموظفين عند تعطل الدومين	استخدام حسابات الطوارئ المحلية المعزولة (Break-Glass Accounts) وبروفيل VPN الطارئ	مفاتيح مشفرة ومحفوظة في خزانة آمنة مع سجل تدقيق	4 ساعات	رئيس البنية التحتية IT
فقدان المقر الرئيسي بالرياض	تفعيل العمل عن بُعد لكافة الموظفين، والتحول الفوري لتشغيل مركز بيانات جدة البديل	2,000 لابتوب مجهزة بـ VPN وشريحة إنترنت بديلة	5 أيام عمل	مدير العمليات التشغيلية
تعطل شبكة سويفت الإلكترونية	التحول لمحطة سويفت الاحتياطية بجدة واستخدام التلكس والتأكيد الهاتفي المشفر للحوالات	قوائم التوقيع المزدوج المعتمدة لدى البنك المركزي	8 ساعات	مدير إدارة الخزينة

مرجع: الجدول 5: ملخص إجراءات العمل اليدوية والبديلة في الطوارئ (Manual workarounds)

سجل الاعتماديات الحرجة ونقاط الفشل الفردية (Critical Dependency Register - SPOF)

يوضح الجدول 6 مكونات البنية التحتية الحرجة وتقييم مخاطر نقاط الفشل الفردية (Single Point of Failure) والحلول المطبقة:

الخدمة / المكون (Service)	نوع الاعتمادية (Type)	نقطة فشل فردية؟ (SPOF)	نهج الاستمرارية والبدائل (Continuity Approach)	RTO / RPO	المالك الداخلي (Internal Owner)
إدارة الهويات (IdP/SSO)	المصادقة والصلاحيات	لا (توزيع جغرافي)	تكرار عبر مراكز البيانات وسحابة Azure مع حسابات Break-glass	2 ساعة / 15 دقيقة	مدير الأنظمة والشبكات
خوادم التسمية (DNS)	توجيه حركة المرور	لا (تعدد المزودين)	مزود DNS رئيسي (Cloudflare) ومزود ثانوي (stc) جاهز للتحويل	1 ساعة / صفر	رئيس أمن الشبكات
مركز بيانات الرياض	الحوسبة وقواعد البيانات	لا (تعدد المراكز)	مركز بيانات جدة مجهز بالكامل (Active-Standby) وقواعد بيانات متزامنة	2 ساعة / 5 دقائق	مدير تقنية المعلومات CTO
الربط الشبكي بين المدن	الاتصالات والاتصال بالإنترنت	لا (مسارات ألياف مزدوجة)	مسارات ألياف بصرية مشفرة ومستقلة جغرافياً عبر مزودين مختلفين	15 دقيقة / صفر	مدير هندسة الشبكات
البريد الإلكتروني للعملاء	المراسلات والتنبيهات	نعم (مزود واحد)	توفير بوابة رسائل SMS وبوابات إشعارات تطبيق الجوال كقنوات بديلة	4 ساعات / 2 ساعة	مشرف الاتصالات الرقمية

مرجع: الجدول 6: سجل الاعتماديات الحرجة وتلافي نقاط الفشل الفردية (Critical dependency register)

سيناريوهات الكوارث وخطة التعافي (Disaster Scenarios & Recovery Plan)

حدد بنك الآفاق الرقمية أربعة سيناريوهات كوارث رئيسية قد تعصف بالعمليات والأنظمة، ووضعت لكل سيناريو خطة تعافي تقنية وتشغيلية دقيقة كما يوضح الجدول 7:

سيناريو الكارثة (Disaster Scenario)	الجهة المسؤولة (Responsible)	خطة التخفيف والتعافي التقني (Recovery Plan)	RTO المستهدف	RPO المستهدف
تلف أو اختراق قواعد البيانات المصرفية أو مستودعات S3	فريق أمن المعلومات (ISG) وهندسة البيانات	عزل البيئة المتضررة فوراً لمنع تلوث السجلات. استعادة البيانات من النسخ الاحتياطية المعزولة أو النسخ المكررة جغرافياً بجدّة. إجراء فحص تكامل وتدقيق جنائي ومطابقة الأرصاد وإعادة المزامنة مع بيئة الإنتاج.	RTO: 4 ساعات	RPO: 1 ساعة
فقدان المقر الرئيسي أو تعطل مركز بيانات الرياض بالكامل	الإدارة العليا، CTO، ومدير استمرارية الأعمال	تفعيل التحول الطارئ (Failover) الفوري إلى مركز بيانات التعافي بجدّة عبر تحويل مسارات الشبكة و DNS. تشغيل الخوادم الأساسية وبوابات الدفع وقنوات الصيرفة من الموقع الاحتياطي. تفعيل العمل عن بُعد للموظفين.	RTO: 2 ساعة	RPO: 5 دقائق
فقدان مستودعات الأكواد البرمجية أو بيئة النشر CI/CD	رئيس هندسة البرمجيات وفريق الدعم التقني	إعادة بناء مستودعات الكود من النسخ الاحتياطية غير المتصلة أو النسخ المتماثلة الموزعة لدى المطورين. إعادة بناء خوادم CI/CD باستخدام نصوص التكوين الآلي (IaC) واستئناف عمليات التحديث الآمن.	RTO: 4 ساعات	RPO: شبه منعدم (Zero)
هجوم فدية واسع يستهدف أجهزة المستخدمين الطرفية (2000 لابتوب)	إدارة تقنية المعلومات IT بمتابعة CISO	عزل الأجهزة المصابة عن الشبكة اللاسلكية والـ VPN. تنفيذ مسح أمني شامل عبر EDR ومسح الأجهزة عن بُعد بواسطة Intune. إعادة تثبيت الصورة الآمنة للنظام (Re-imaging) للمحطات المتضررة وتفعيل التشفير BitLocker.	RTO: 24 ساعة	RPO: غير منطبق

مرجع: الجدول 7: خطط وسيناريوهات الاستجابة والتعافي من الكوارث (Disaster Scenarios & Recovery Plan)

خطط الاستجابة والتواصل أثناء الكوارث (Incident Response & Communication Plans)

تتضمن هذه الخطة بشكل وثيق مع 'إجراءات الاستجابة لحوادث أمن المعلومات (ISMS-DOC-A05-26-1)'. وتتم إدارة الأزمة الكارثية بالمراحل السبع المعتمدة:

- المرحلة الأولى: 1. رصد وتقييم الحادث: اكتشاف الحدث وتحديد ما إذا كان يمثل كارثة تتطلب تفعيل خطة الاستمرارية.
- المرحلة الثانية: 2. قرار التفعيل: اجتماع طارئ لمدير الحادث (CISO) مع الرئيس التنفيذي والإعلان الرسمي لتفعيل خطة DR/BCP.
- المرحلة الثالثة: 3. التصعيد والتواصل الداخلي: فتح غرفة العمليات (War Room) وإخطار الفرق الفنية والإدارية المعنية فوراً.
- المرحلة الرابعة: 4. عمليات الاستعادة والتعافي: تنفيذ مسارات التحول التقني لمركز بيانات جدة أو استعادة النسخ المعزولة.
- المرحلة الخامسة: 5. إحاطة أصحاب المصلحة: إرسال تحديثات دورية منتظمة للإدارة العليا، البنك المركزي SAMA، والعملاء.
- المرحلة السادسة: 6. حل الأزمة واستعادة الوضع الطبيعي: التحقق من استقرار الخدمات وإعلان إنهاء حالة الطوارئ (Stand-Down).
- المرحلة السابعة: 7. مراجعة ما بعد الحادث والدروس المستفادة: عقد اجتماع تقييمي خلال 10 أيام عمل وإعداد التقرير النهائي.

خطة التواصل والرسائل المعتمدة (Communication Plan)

يوضح الجدول 8 قنوات الاتصال، الأطر الزمنية للإشعار، ونقاط التصعيد المعتمدة أثناء تفعيل الخطة:

المسؤول (Owner)	نقاط التصعيد والملاحظات (Notes)	الجدول الزمني للإشعار (Timeline)	قناة الاتصال / الفئة المستهدفة (Channel / Audience)
قائد فريق الاستجابة (CISO)	فتح قناة Teams مشفرة؛ في حال تعطلها يتم تفعيل شجرة الاتصال الهاتفي والرسائل النصية	فوري (خلال دقائق من إعلان الحادث)	فريق الاستجابة للطوارئ والمهندسون (IRT)
CISO ومسؤول الاستمرارية	اتصال هاتفي مباشر برئيس مجلس الإدارة والرئيس التنفيذي، وعقد إحاطة كل ساعتين	خلال 30 دقيقة من تشخيص الكارثة	الإدارة التنفيذية العليا ومجلس الإدارة
إدارة الموارد البشرية والاتصال	توجيهات العمل عن بُعد أو الانتقال لمواقع بديلة؛ إرسال رسائل SMS عند تعطل الإيميل	خلال 1 ساعة من تفعيل الخطة	كافة موظفي البنك (إعلان وتوجيه داخلي)
فريق رعاية العملاء والاتصال	نشر بيان رسمي على صفحة حالة البنك الخارجية؛ تفعيل مركز الاتصال وتجنب التصريحات الفردية	خلال 4 ساعات كحد أقصى	العملاء المتأثرون والمودعون
الشؤون القانونية والمالية	إشعار إدارة الرقابة على الأمن السيبراني في SAMA، وإخطار شركة التعاونية لحفظ التعويض	خلال ساعتين للبنك المركزي و24 ساعة للتأمين	البنك المركزي السعودي (SAMA) وشركة التأمين

مرجع: الجدول 8: مصفوفة وخطة التواصل أثناء الكوارث (Communication Plan)

المراجعة والصيانة والاختبار المستمر (Review, Maintenance & Testing)

تخضع هذه الوثيقة لمراجعة وتحديث سنوي إلزامي، أو فور حدوث تغييرات جوهرية في البنية التحتية للبنك ومراكز البيانات.

جدول الاختبارات والتمارين الدورية المستقبلية (Forward Test Schedule - 12 Months):

- الربع الأول (Q1): تمرين محاكاة مكتبي (Tabletop Exercise) لسيناريو هجوم فدية واختراق الفروع.
- الربع الثاني (Q2): اختبار استعادة قواعد بيانات الصيرفة والأنظمة الأساسية في بيئة نظيفة معزولة.
- الربع الثالث (Q3): تمرين محاكاة تعطل بوابات الدفع ومزودي خدمات التسمية (DNS Failover).
- الربع الرابع (Q4): محاكاة التحول التشغيلي الكامل من مركز بيانات الرياض لمركز بيانات جدة البديل.

حفظ الشواهد والوصول دون اتصال: يتم حفظ وتوثيق نتائج وتوقيات كل اختبار في سجلات نظام إدارة أمن المعلومات ورفع تقرير النتائج لمراجعة الإدارة العليا ولجنة المخاطر. النسخة الاحتياطية غير المتصلة (Offline Access): يتم الاحتفاظ بنسخ رقمية مشفرة على أجهزة الهواتف المؤمنة لقائد الفريق، مع حفظ نسخة مطبوعة في حقيبة الطوارئ (Grab-Bag) بمقر البنك.

الملاحق (Appendices)

الملحق أ: استمارة بيانات الاتصال في الطوارئ (Appendix A - Contact Information)

الملاحظات (Notes)	بيانات الاتصال (Contact Details)	الدور في خطة الطوارئ (Role)	الاسم / الجهة (Contact)
صلاحية التفعيل وإنهاء الطوارئ	هاتف: +966 11 400 1101 جوال: +966 50 123 4501	مدير الحادث (Incident Manager - CISO)	أ. سارة الحربي
تنسيق خطط العمل البديلة والجاهزية	هاتف: +966 11 400 1109 جوال: +966 50 123 4509	مسؤول استمرارية الأعمال (BC Lead)	أ. ريان السبيعي
إدارة عمليات الاستعادة وسيرفرات جدة	هاتف: +966 11 400 1104 جوال: +966 50 123 4504	مسؤول التعافي التقني (Tech Recovery Lead)	م. خالد السالم
إدارة البيانات والرسائل الرسمية	هاتف: +966 11 400 1110 جوال: +966 50 123 4510	مسؤول الاتصال المؤسسي (Comms Lead)	أ. مشعل الرويلي
متابعة استجابة AWS و stc ومزودي الخدمة	هاتف: +966 11 400 1103 جوال: +966 50 123 4503	مسؤول الأدلة والموردين (Supplier Lead)	م. فهد الشمري

مرجع: الجدول 9: بيانات الاتصال في حالات الطوارئ (Appendix A - Contact Information)

الملحق ب: الأدوار والنواب المعينون (Appendix B - Roles with Named Alternates)

الدور (Role)	المسؤول الأصلي (Primary)	النائب المعين (Alternate)	ملاحظات التفويض (Notes)
مدير الحادث (Incident Manager)	أ. سارة الحربي (CISO)	محمد عبدالغني العامري (كبير أخصائيي الأمن)	تفويض كامل للصلاحيات التنفيذية
مسؤول استمرارية الأعمال (BC Lead)	أ. ريان السبيعي	أ. زياد الرشيد	تنسيق المواقع البديلة وحسابات الطوارئ
مسؤول التعافي التقني (Tech Recovery)	م. خالد السالم (CTO)	م. طارق العتيبي (مدير البنية التحتية)	إدارة خوادم الرياض وجدة والسحابة
مسؤول الاتصال والإعلام (Comms Lead)	أ. مشعل الرويلي	أ. لمى التميمي	إصدار البيانات الصحفية والإشعار
مسؤول إدارة الموردين (Supplier Lead)	م. فهد الشمري	م. خالد المطيري	تفعيل اتفاقيات الدعم مع AWS و stc

مرجع: الجدول 10: قائمة الأدوار والنواب المعتمدين (Appendix B - Named Alternates)

الملحق ج: قائمة التحقق الميدانية للتفعيل (Appendix C — DR/BCP Activation Checklist)

🔗 قائمة التحقق المعتمدة لتفعيل خطة الاستمرارية والتعافي: قائمة التحقق الميدانية للتفعيل من 10 خطوات (10- Step Operational Checklist):

1. السلامة أولاً والتأكد من أمان الموظفين؛ وفتح تذكرة الحادث الطارئ وسجل التوثيق الزمني.
2. تعيين مدير الحادث (أو نائبه في حال غيابه)؛ وفتح قناة الاتصال المخصصة للطوارئ.
3. تقييم الموقف مقابل معايير التفعيل؛ وإعلان تفعيل خطة DR/BCP رسمياً عند استيفاء الشروط.
4. احتواء التهديد وإيقاف أي تغييرات تقنية غير ضرورية، والتحفيز على الأدلة الجنائية الرقمية.
5. إرسال الإشعار والتحديث المبني لأصحاب المصلحة والإدارة التنفيذية وتحديد موعد الإحاطة القادمة.
6. تشغيل وتطبيق دليل إجراءات التعافي المخصص للسيناريو (سحابة S3، مركز البيانات، الفدية).
7. تنفيذ التحول التقني (Failover) أو استعادة النسخ؛ والتحقق من RTO و RPO ومطابقة أرصدة العمليات.
8. تفعيل إجراءات العمل اليدوية والبديلة فوراً في الإدارات التشغيلية عند الحاجة.
9. استمرار تقديم التحديثات الزمنية المحددة للجهات المعنية حتى عودة الأنظمة لحدود التشغيل الآمن.
10. إعلان إنهاء حالة الطوارئ (Stand-Down) رسمياً، وإجراء مراجعة الدروس المستفادة خلال 10 أيام عمل.